

## MARCO INTEGRATIVO GQM+ PRAGMATIC PARA ACET

### Alineación Estratégica-Operativa-Técnica de Indicadores de Ciberseguridad

**Versión:** 1.0 | **Fecha:** Enero 2026 | **Ámbito:** Organizaciones España (Todas las tamaños)

#### 1. INTRODUCCIÓN: EL PROBLEMA DE ALINEACIÓN

Las organizaciones típicamente enfrentan un "desconexión de tres niveles":

NIVEL EJECUTIVO (Junta/CEO):

"Necesitamos reducir riesgo 30% y cumplir NIS2"

↓ DESCONEXIÓN

NIVEL DIRECTIVO (CISO/IT Management):

"Implementaremos SIEM, MFA, capacitación..."

↓ DESCONEXIÓN

NIVEL OPERATIVO (SOC/Security Team):

"Hoy monitoreamos 15.000 eventos por minuto"

↓

REALIDAD:

¿Contribuyen estos 15.000 eventos al objetivo de reducir riesgo 30%?

¿O solo son "ruido"?

RESPUESTA: Sin GQM+PRAGMATIC, DESCONOCES.

**Solución:** Marco integrador que garantiza trazabilidad desde Business Goal hasta Metric técnica.

#### 2. ESTRUCTURA DEL MARCO GQM+ PRAGMATIC

##### Nivel 0: Business Goal (Dirección Empresarial)

**Definición:** Objetivo estratégico de la organización, expresado en términos empresariales/financieros.

##### Ejemplos:

Goal BG-1: "Mejorar confianza cliente en 25% (NPS +15 puntos)"

Goal BG-2: "Cumplir regulaciones NIS2 al 100% antes Oct 2026"

Goal BG-3: "Reducir costo incidentes ciberseguridad en 40%"

Goal BG-4: "Posicionar como líder seguridad en sector (ranking Gartner)"

**Responsable:** Junta Directiva, CEO, CFO

**Horizonte:** 12-36 meses

##### Nivel 1: Security Goal (Dirección de Seguridad)

**Definición:** Objetivo de ciberseguridad que contribuye directamente a Business Goal.

**Mapeo:** Para cada BG, derivar 2-3 Security Goals.

**Ejemplo:** Mapeo BG-1 – Security Goals

#### Business Goal BG-1:

"Mejorar confianza cliente en 25% (NPS +15)"

↓ Mapeo

#### Security Goal SG-1.1:

"Reducir tiempo notificación breach a <72h (GDPR compliance)"

↓ Beneficio:

Si reducimos MTTD de 6 meses a 2 semanas, clientes perciben control.

NPS correlaciona con "confianza en seguridad" (encuestas de satisfacción).

#### Security Goal SG-1.2:

"Eliminar breaches por vulnerabilidades públicas conocidas"

↓ Beneficio:

Evita headlines negativos (tipo "Startup breachada por CVE-2024-1234").

Confianza cliente = "No tienen vulnerabilidades públicas".

#### Security Goal SG-1.3:

"Comunicación transparente post-incidente (status.page.io, webinar explicativo)"

↓ Beneficio:

Clientes valoran transparencia más que secretismo.

**Responsable:** CISO, IT Director, Chief Risk Officer

**Horizonte:** 6-18 meses

### Nivel 2: Measurement Goal (Operacionalización)

**Definición:** Objetivo de medición que operacionaliza un Security Goal.

**Estructura:** Para cada SG, especificar 2-4 Measurement Goals (MG) que sean técnicamente medibles.

#### Ejemplo: Mapeo SG-1.1 – Measurement Goals

#### Security Goal SG-1.1:

"Reducir tiempo notificación breach a <72h (GDPR compliance)"

↓ Desglose en Measurement Goals

#### Measurement Goal MG-1.1.1:

"Detectar breach en <2 horas (MTTD)"

Lógica: Si detectas en 2h, tienes 70h para investigar + notificar.

#### Measurement Goal MG-1.1.2:

"Investigar y clasificar breach en <24 horas (MTTR-Classify)"

Lógica: Necesitas saber severidad antes de notificar.

#### Measurement Goal MG-1.1.3:

"Notificar a AEPD en <72 horas desde descubrimiento"

Lógica: Cumplimiento GDPR Art. 33.

**Responsable:** SOC Lead, Security Analytics Manager

**Horizonte:** Ongoing, seguimiento mensual

### Nivel 3: Questions (Operacionalización Detallada)

**Definición:** Preguntas específicas que desglosan cada MG en áreas de investigación.

#### Ejemplo: MG-1.1.1 – Questions

Measurement Goal MG-1.1.1:

"Detectar breach en <2 horas (MTTD)"

↓ Preguntas Derivadas

Question Q-1.1.1.1:

"¿Tenemos visibilidad de >85% de sistemas vía SIEM?"

Question Q-1.1.1.2:

"¿Están habilitadas alertas de IOCs (Indicators of Compromise) conocidos?"

Question Q-1.1.1.3:

"¿Se correlacionan eventos para detectar patrones de ataque?"

Question Q-1.1.1.4:

"¿Se escalan automáticamente alertas críticas al SOC en <5 min?"

**Responsable:** SOC Analyst, Security Engineer

#### Nivel 4: Metrics (Cuantificación)

**Definición:** Métricas técnicas cuantificables que responden preguntas.

#### Ejemplo: Questions → Metrics

Question Q-1.1.1.1: "¿Tenemos visibilidad >85% de sistemas?"

└ Métrica M-1.1.1.1:

KPI =  $(\text{Sistemas\_con\_logs\_en\_SIEM} / \text{Total\_Sistemas}) \times 100$

Actual: 78%

Target: ≥85%

Frecuencia: Mensual

Data Source: SIEM console, inventario activos

Question Q-1.1.1.2: "¿Alertas IOCs habilitadas?"

└ Métrica M-1.1.1.2:

KPI =  $\% \text{ Reglas IOC activas} / \text{Reglas IOC diseñadas}$

Actual: 92%

Target: 100%

Frecuencia: Semanal

Data Source: SIEM rules engine

Question Q-1.1.1.3: "¿Se correlacionan eventos?"

└ Métrica M-1.1.1.3:

KPI =  $(\text{Incidentes\_detectados\_por\_correlación} / \text{Total\_Incidentes}) \times 100$

Actual: 45%

Target: >60%

Frecuencia: Mensual

Data Source: SIEM incident logs, classification

Question Q-1.1.1.4: "¿Escalada automática <5 min?"

└ Métrica M-1.1.1.4:

KPI =  $(\text{Alertas\_esclarecidas\_<5min} / \text{Alertas\_totales\_críticas}) \times 100$

Actual: 88%

Target: ≥95%

Frecuencia: Real-time

Data Source: SIEM workflow logs, timestamps

**Responsable:** Data Analyst, SOC Metrics Owner

### 3. MATRIZ GQM: EJEMPLO COMPLETO (Dominio DETECTAR)

| Level           | Goal                             | Question              | Metric                  | PRAGMATIC Score |
|-----------------|----------------------------------|-----------------------|-------------------------|-----------------|
| <b>BG-1</b>     | Mejorar NPS cliente 25%          | —                     | —                       | —               |
| <b>SG-1.1</b>   | Reducir notificación breach <72h | —                     | —                       | —               |
| <b>MG-1.1.1</b> | MTTD <2h                         | ¿Cobertura SIEM >85%? | SIEM_Coverage %         | 7/9             |
| <b>MG-1.1.1</b> | MTTD <2h                         | ¿IOCs activos 100%?   | IOC_Rules_Active %      | 8/9             |
| <b>MG-1.1.1</b> | MTTD <2h                         | ¿Correlación eventos? | Correlation_Detection % | 8/9             |
| <b>MG-1.1.1</b> | MTTD <2h                         | ¿Escalada <5 min?     | Escalation_Time (min)   | 8/9             |

### 4. EVALUACIÓN PRAGMATIC: 9 CRITERIOS

Para cada Metric, evaluar según 9 criterios (0 = No cumple, 3 = Cumple totalmente):

#### Criterio 1: Predictivo (P) – ¿Predice problemas futuros?

**Pregunta:** ¿Si mejora esta métrica, anticipamos mejor comportamiento de seguridad?

##### Ejemplo MTTD:

- Si MTTD mejora de 6h → 2h, predecimos que daño será menor (menos datos exfiltrados)
- Score: **3/3** (altamente predictivo)

#### Criterio 2: Relevante (R) – ¿Importa a stakeholders?

**Pregunta:** ¿Ejecutivos/empleados/clientes ven valor en esta métrica?

##### Ejemplo MTTD:

- Ejecutivos: "¿Detectamos rápido?" → Sí, MTTD es central
- CEO: "¿Cumplimos GDPR?" → Sí, notificación <72h depende de MTTD
- Score: **3/3** (altamente relevante)

#### Criterio 3: Accionable (A) – ¿Guía decisiones?

**Pregunta:** Si la métrica baja, ¿sabemos exactamente qué hacer?

##### Ejemplo MTTD bajo (6h):

- Acción 1: Revisar reglas SIEM (¿están tuned correctamente?)
- Acción 2: Aumentar capacidad SOC (¿tenemos suficientes analistas?)
- Acción 3: Mejorar correlación (¿usamos ML/AI?)
- Score: **3/3** (muy accionable)

#### **Criterio 4: Genuino (G) – ¿Mide qué pretende medir?**

**Pregunta:** ¿Timestamp\_Detección es realmente cuándo detectamos? ¿O cuándo registramos?

##### **Ejemplo MTTD:**

- Riesgo: SIEM reporta timestamp como "cuando el evento ingresó a SIEM"
- No: Cuando analista lo marcó "confirmado incidente"
- Validación: Auditar 10 casos recientes, verificar timestamps con logs manuales
- Score: **2/3** (parcialmente genuino, requiere validación cruzada)

#### **Criterio 5: Significativo (S) – ¿Tiene peso empresarial?**

**Pregunta:** ¿Impacta en dinero, regulación, reputación?

##### **Ejemplo MTTD:**

- \$: Cada hora de delay = €5K-10K en daño potencial
- Regulación: GDPR notificación <72h depende directamente
- Reputación: Si clientes ven "6 meses para detectar", pierden confianza
- Score: **3/3** (altamente significativo)

#### **Criterio 6: Preciso (Pr) – ¿Medición confiable?**

**Pregunta:** ¿Pueden dos analistas medir lo mismo y obtener resultado idéntico?

##### **Ejemplo MTTD:**

- Sí: Timestamp es automático, no subjetivo
- Riesgo: Si hay múltiples eventos en mismo incidente, ¿cuál "inicio"?
- Validación: Estándar documentado (ej. "primer evento correlacionado")
- Score: **3/3** (muy preciso, automático)

#### **Criterio 7: Oportuno (O) – ¿Datos disponibles rápidamente?**

**Pregunta:** ¿Cuánto demora entre recolección y disponibilidad ejecutiva?

##### **Ejemplo MTTD:**

- SIEM recolecta: Real-time
- SIEM procesa: <5 min
- Dashboard ejecutivo: Actualiza cada hora
- Reporte Junta: Mensual
- Score: **3/3** (datos oportuno)

#### **Criterio 8: Independiente (I) – ¿Libre de sesgo?**

**Pregunta:** ¿Puede el SOC manipular la métrica sin mejorar seguridad real?

##### **Ejemplo MTTD:**

- Riesgo: "Cambiar timestamp inicio del evento = reducir MTTD ficticiamente"
- Validación cruzada: Auditor externo verifica 10% de incidentes
- Score: **2/3** (parcialmente independiente, requiere auditoría)

### Criterio 9: Rentable (Re) – ¿Costo colección << beneficio?

**Pregunta:** ¿Cuánto cuesta medir esta métrica vs. valor que proporciona?

#### Ejemplo MTTD:

- Costo recolección: €0 (automática en SIEM, incluido en licencia)
- Costo análisis: 2h/mes analista (~€200)
- Valor: Evita breach €5M+ → ROI 25,000x
- Score: **3/3** (extremadamente rentable)

## 5. MATRIZ PRAGMATIC: TEMPLATE GENERAL

|                                                                                                           |                                    |
|-----------------------------------------------------------------------------------------------------------|------------------------------------|
| MÉTRICA: [Nombre KPI]                                                                                     |                                    |
| Goal Jerárquico:<br>BG: [Business Goal]<br>SG: [Security Goal]<br>MG: [Measurement Goal]<br>Q: [Question] |                                    |
| EVALUACIÓN PRAGMATIC (0-3 cada criterio):                                                                 |                                    |
| P (Predictivo):                                                                                           | ___/3 → ¿Predice problemas?        |
| R (Relevante):                                                                                            | ___/3 → ¿Importa a stakeholders?   |
| A (Accionable):                                                                                           | ___/3 → ¿Guía decisiones?          |
| G (Genuino):                                                                                              | ___/3 → ¿Mide qué pretende?        |
| S (Significativo):                                                                                        | ___/3 → ¿Impacta negocio?          |
| Pr (Preciso):                                                                                             | ___/3 → ¿Repetible/confiable?      |
| O (Oportuno):                                                                                             | ___/3 → ¿Datos disponibles rápido? |
| I (Independiente):                                                                                        | ___/3 → ¿Libre de sesgo?           |
| Re (Rentable):                                                                                            | ___/3 → ¿Costo << beneficio?       |
| SCORE TOTAL PRAGMATIC: ___/27                                                                             |                                    |
| % PRAGMATIC = (Score/27) × 100 = ___%                                                                     |                                    |
| INTERPRETACIÓN:                                                                                           |                                    |
| >90% (27-25): EXCELENTE (métrica debe implementarse)                                                      |                                    |
| 80-90% (24-22): BUENO (implementar, mejoras opcionales)                                                   |                                    |
| 70-80% (21-19): ACEPTABLE (requiere validación cruzada)                                                   |                                    |
| <70% (18-15): POBRE (reconsiderar métrica)                                                                |                                    |

## 6. EJEMPLO COMPLETO: APLICACIÓN A ACET

**Caso:** Implementar Métrica "MTTD <2 horas"

**Paso 1:** Mapeo Jerárquico GQM

BG-1: "Mejorar confianza cliente 25% (NPS +15)"  
 ↓ Contribuye  
 SG-1.1: "Reducir notificación breach <72h (GDPR Art. 33)"  
 ↓ Requiere  
 MG-1.1.1: "Detectar incidentes en <2 horas (MTTD)"  
 ↓ Medido por  
 Q-1.1.1.1: "¿Tiempo desde ataque hasta detección <2h?"  
 ↓ Operacionalizado  
 M-1.1.1.1:  $MTTD = \text{Timestamp\_Detección} - \text{Timestamp\_Inicio}$

## Paso 2: Evaluación PRAGMATIC

| Criterio                 | Evaluar                       | Score | Razón                                  |
|--------------------------|-------------------------------|-------|----------------------------------------|
| <b>P (Predictivo)</b>    | ¿Si ↓ MTTD, ↓ daño?           | 3/3   | Menos tiempo = menos datos exfiltrados |
| <b>R (Relevante)</b>     | ¿Importa CEO?                 | 3/3   | SÍ, central en GDPR compliance         |
| <b>A (Accionable)</b>    | ¿Si MTTD ↑, qué hacer?        | 3/3   | Tune SIEM, capac. SOC, ML/AI           |
| <b>G (Genuino)</b>       | ¿Timestamp = detección real?  | 2/3   | Requiere validación (falsos positivos) |
| <b>S (Significativo)</b> | ¿Impacta \$, reg, reputación? | 3/3   | €5K-10K/hora delay, GDPR, NPS          |
| <b>Pr (Preciso)</b>      | ¿Automático, repetible?       | 3/3   | Sí, timestamp determinístico           |
| <b>O (Oportuno)</b>      | ¿Datos en <24h?               | 3/3   | Real-time SIEM dashboard               |
| <b>I (Independiente)</b> | ¿Auditable?                   | 2/3   | Requiere auditoría externa             |
| <b>Re (Rentable)</b>     | ¿ROI positivo?                | 3/3   | €0 colección, €1M evitado              |
|                          | TOTAL                         | 24/27 | 89% PRAGMATIC ✓<br>IMPLEMENTAR         |

## Paso 3: Plan de Acción

- ✓ MÉTRICA VÁLIDA (89% PRAGMATIC)
  - Implementar MTTD en dashboard mes 1
  - Validación cruzada: Auditor externo 10% casos mes 2
  - Automatizar alertas SOC mes 3
  - Target: MTTD <2h en Q2 2026

## 7. CONCLUSIÓN

El **Marco GQM+ PRAGMATIC** asegura que:

1. Trazabilidad Vertical: Business Goal → Security Goal → Measurement Goal → Question → Metric
2. Validación Horizontal: Cada métrica se evalúa contra 9 criterios pragmáticos
3. Impacto Comprobable: Cada métrica contribuye explícitamente a un objetivo empresarial
4. Gobernanza Clara: Responsabilidades y frecuencias definidas en cada nivel

**Resultado:** Indicadores de ciberseguridad que son técnicamente válidos, empresarialmente relevantes, y operacionalmente accionables.

**Uso:** Este marco es la base conceptual para las Matrices de Evaluación PRAGMATIC que seguirán en documentos posteriores.